

ML-1384 – Marine plan policies: render policy wording (unicode / HTML sanitisation)

Manual test evidence

Date: 21 July 2026

Tester: Manual test (Playwright MCP + backend sanitiser demonstration)

Environment: Local Docker (frontend/backend on main), <http://localhost:3000>

Submitted application reference: MLA/2026/10381

How the wording is cleaned (implementation)

The clean-up is performed in the backend by `sanitisePolicyWording()` (`src/marine-licences/api/helpers/marine-plan-policies/sanitise-policy-wording.js`), a two-pass `sanitize-html` transform applied when the policy wording is fetched from the `marine-plans-explorer` policies API and stored. The frontend then renders the already-clean wording as markup via the `appMarineLicencePolicyWording` macro (`{{ params.html | safe }}`), so the same cleaned wording is used everywhere the wording is shown.

Allowed formatting tags: `p`, `br`, `a`, `ol`, `ul`, `li`, `strong`, `em`, `sup`, `sub`. Tags dropped entirely (content removed): `script`, `style`, `textarea`, `option`, `xmp`, `noscript`, `iframe`, `object`, `embed`. Any other tag (e.g. `span`, `div`, `h1-h6`, `img`, `table`) is removed but its text is kept. `b` -> `strong` and `i` -> `em` are normalised; anchors keep only `http/https` hrefs (dead/fragment anchors are unwrapped to text; external links get `rel="noopener noreferrer"`); non-breaking and invisible characters are normalised.

AC1 – Unicode characters in the wording (e.g. `\u003C` and `\u003E`) are translated into ASCII

Policy wording is delivered as JSON in which angle brackets are unicode-escaped (`\u003C`, `\u003E`). When parsed these become real `"<"/>"` characters, and the resulting tags are then applied as formatting rather than shown as escaped text. No literal `\u003C` / `\u003E` / `<` / `>`; leaks into the rendered output.

Status: **PASS**

AC2 – HTML tags in the translated text are applied as formatting (not rendered as plain text)

e.g. `"<p>Hello world</p>"` renders as a paragraph containing "Hello world". On the View details page the wording renders as real `<p>` and `<ol><li>` elements; the DOM contains no literal `"<p>"/>"<li>"` text.

Status: **PASS**

AC3 – `<span>` and `<script>` tags are ignored

`<span>` is removed but its text is kept (`"<span>span text</span><p>para</p>"` -> `"span text<p>para text</p>"`); `<script>` is dropped entirely including its content (`"<script>alert(1)</script><p>safe</p>"` -> `"<p>safe text</p>"`). No `<span>` or `<script>` elements appear in the rendered wording.

Status: **PASS**

Question in AC3 – "Any others we should ignore?"

Yes. In addition to script and span, the sanitiser drops the content of style, textarea, option, xmp, noscript, iframe, object and embed entirely, and strips any other non-allowed tag (div, h1-h6, img, table, button, etc.) to its text. Only p, br, a, ol, ul, li, strong, em, sup, sub are kept as formatting. This is worth confirming with the BA as the intended allow-list.

Status: PASS (documented)

NOTE – the clean wording is used everywhere the policy wording is displayed

Verified on the View details page (internal from the dashboard and the public view-public-details URL) and the Check your answers page (per ML-1377 evidence) — all render the wording via the same appMarineLicencePolicyWording macro fed by the same backend-sanitised data. The Dynamics 365 "Marine plan policies" tab consumes the same sanitised wording from the backend but requires real DEFRA ID + Dynamics and was out of scope for the local run.

Status: PASS (D365 not exercised locally)

Evidence 1 — backend sanitiser run against crafted "dirty" inputs

Ran the actual production sanitiser (sanitisePolicyWording) inside the running backend container against inputs containing unicode escapes, HTML tags, , <script> and other tags. IN = raw input, OUT = cleaned wording that is rendered:

```
* AC1 unicode escapes \u003C/\u003E (after JSON parse)
  IN : "<p>Hello world</p>"
  OUT: "<p>Hello world</p>"

* AC2 HTML applied as formatting
  IN : "<p>Intro</p><ol><li>one</li><li>two</li></ol>"
  OUT: "<p>Intro</p><ol><li>one</li><li>two</li></ol>"

* AC3 <span> ignored (text kept)
  IN : "<span>span text</span><p>para text</p>"
  OUT: "span text<p>para text</p>"

* AC3 <script> ignored (content dropped)
  IN : "<script>alert(1)</script><p>safe text</p>"
  OUT: "<p>safe text</p>"

* Other: <div>/<h1> stripped to text
  IN : "<div><h1>Heading</h1></div><p>body</p>"
  OUT: "Heading<p>body</p>"

* Other: <style>/<iframe> dropped
  IN : "<style>.x{}</style><iframe src=x</iframe><p>ok</p>"
  OUT: "<p>ok</p>"

* b->strong, i->em
  IN : "<b>bold</b> and <i>italic</i>"
  OUT: "<strong>bold</strong> and <em>italic</em>"

* dead anchor unwrapped, real link kept
  IN : "<a href=\"#frag\">frag</a> <a href=\"https://gov.uk\">
target=\"_blank\">GOV.UK</a>"
  OUT: "frag <a href=\"https://gov.uk\" target=\"_blank\" rel=\"noopener
noreferrer\">GOV.UK</a>"
```

Evidence 2 — rendered wording on the View details page

The Marine plan policies card on View details renders each policy's wording as formatted HTML (paragraphs and a numbered list), not as escaped text. DOM inspection confirmed <p> and elements, no /<script> elements, and no literal "<p>" or "\u003C" text.

Marine plan policies

E-AGG-3

Policy information

Within defined areas of high potential aggregate resource, proposals should demonstrate in order of preference:

1. that they will not, prevent aggregate extraction
2. how, if there are adverse impacts on aggregate extraction, they will minimise these
3. how, if the adverse impacts cannot be minimised, they will be mitigated
4. the case for proceeding with the application if it is not possible to minimise or mitigate the adverse impacts

Your consideration

UPDATED via Change from Check your answers: the proposal remains fully compatible with this policy.

E-BIO-1

Policy information

Appropriate weight should be attached to biodiversity, reflecting the need to protect biodiversity as a whole, taking account of the best available evidence including on habitats and species that are protected or of conservation concern in the East marine plans and adjacent areas (marine, terrestrial).

Your consideration

We have assessed this policy and designed the buoy deployment to be fully compatible with it, avoiding any adverse effects.

E-BIO-2

Policy information

Where appropriate, proposals for development should incorporate features that enhance biodiversity and geological interests.

Your consideration

We have assessed this policy and designed the buoy deployment to be fully compatible with it, avoiding any adverse effects.

E-CAB-1

Policy information

Preference should be given to proposals for cable installation where the method of installation is burial. Where burial is not achievable, decisions should take account of protection measures for the cable that may be proposed by the applicant.

Your consideration

We have assessed this policy and designed the buoy deployment to be fully compatible with it, avoiding any adverse effects.

E-MPA-1

Policy information

Any impacts on the overall Marine Protected Area network must be taken account of in strategic level measures and assessments, with due regard given to any current agreed advice on an ecologically coherent network.

Your consideration

We have assessed this policy and designed the buoy deployment to be fully compatible with it, avoiding any adverse effects.

Summary

Acceptance criteria	Result	
AC1 unicode -> ASCII	PASS	
AC2 HTML applied as formatting	PASS	
AC3 span/script ignored (+ others)	PASS	
Used everywhere (CYA/View details)	PASS	D365 not local